embarca tech | Residência Tecnológica em Sistemas Embarcados

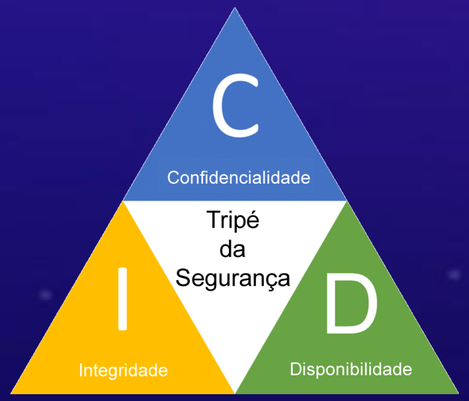
Segurança em IoT – Parte 1

RESIDÊNCIA – Aula Síncrona (17/06/2025)

Prof. Dr Ricardo Menezes Prates

Executores:
INSTITUTO FEDERAL Piauí
INSTITUTO FEDERAL Rio Grande do Norte
INSTITUTO FEDERAL Maranhão
INSTITUTO FEDERAL Ceará
cepedi
INSTITUTO HARDWARE BR
Coordenação: Softex
Iniciativa: MINISTÉRIO DA CIÊNCIA, TECNOLOGIA E INOVAÇÃO
GOVERNO FEDERAL BRASIL UNIÃO E RECONSTRUÇÃO

- *Introdução*
  - Planejamento da aula
- Riscos em IoT
  - *Malware*
  - *Ataque DDoS*
  - *Spoofing*
- Princípios básicos em segurança da informação
  - *Confidencialidade*
  - *Integridade*
  - *Disponibilidade*
- Conclusões

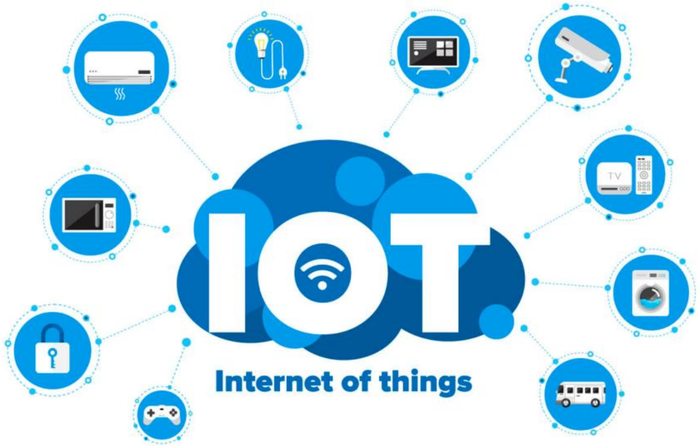


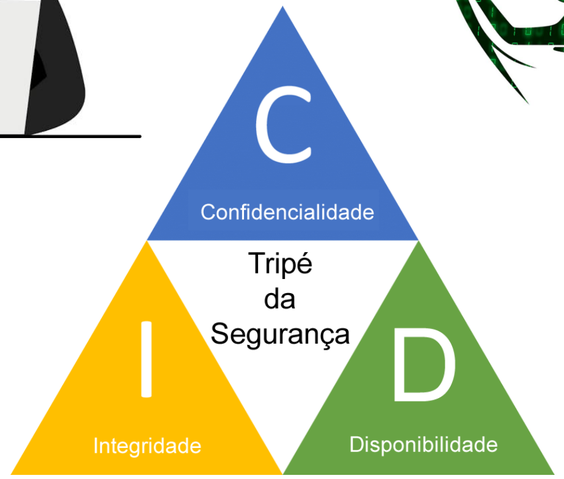
Introdução

Objetivos

- Explorar os conceitos teóricos fundamentais de segurança da informação no contexto de Internet da Coisas (IoT).

- Avaliar desafios de segurança e boas práticas para mitigar ameaças mais típicas, a exemplo de malwares, ataques distribuídos de negação de serviço (DDoS) e *spoofing*.





Planejamento da Aula

- Pré-requisitos para esta aula:

✓ Conceitos de IoT.

✓ Protocolos de comunicação.

- Assunto que será trabalhado na Parte 2:

✓ Criptografia.

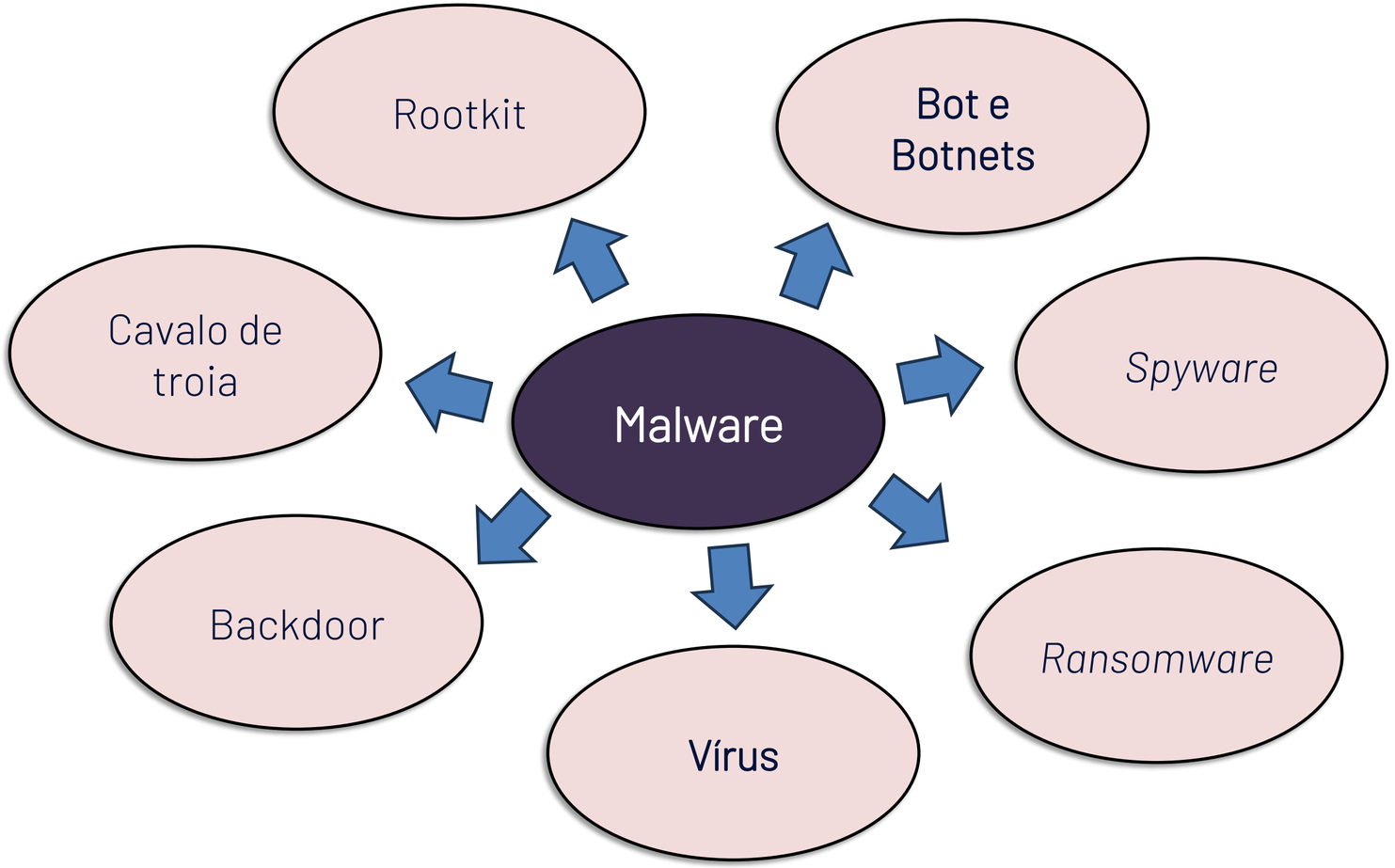
Riscos em IoT

Malware

- Malware:

✓ É um termo genérico que se refere a qualquer tipo de *software* malicioso projetado para danificar, roubar ou comprometer a segurança de um sistema de computador, dispositivo móvel ou rede.

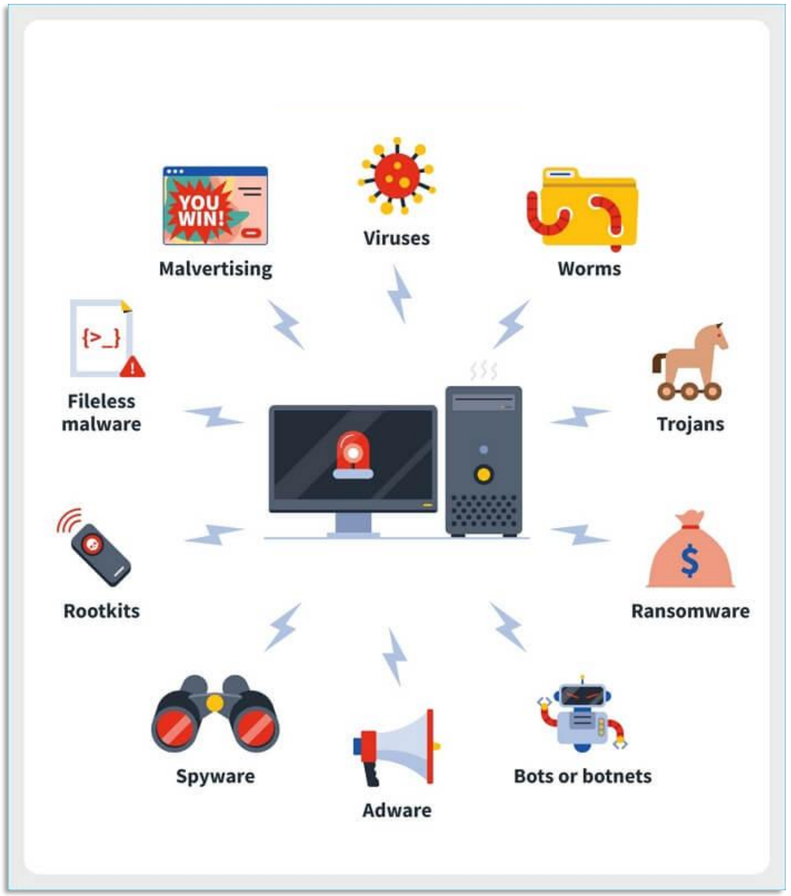
✓ **Malware de dispositivo**: malware que infecta dispositivos IoT específicos, como câmeras de segurança, eletrodomésticos, sensores etc.



Malware

- *Malware*:

1. **Vírus**: Se replica e se espalha para outros arquivos e sistemas.
2. **Trojans (Cavalo de Troia)**: Se disfarça como um software legítimo, mas tem intenções maliciosas.
3. *Ransomware*: Criptografa os arquivos do usuário e exige um resgate para liberá-los.
4. **Adware**: um tipo de malware que exibe anúncios indesejados e pode coletar informações sobre o usuário.
5. **Rootkits**: um tipo de malware que se esconde no sistema operacional e permite que o atacante acesse o sistema sem ser detectado.
6. *Botnets*: redes de dispositivos IoT infectados que podem ser controlados remotamente por atacantes.



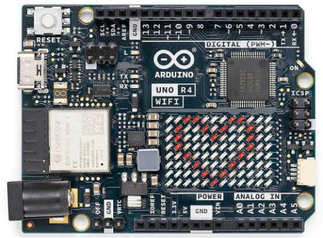
Malware

- Desafios na segurança de dispositivos/redes IoT:

1. **Diversidade de dispositivos:** a variedade de dispositivos IoT torna difícil garantir a segurança completa da rede.

2. **Recursos limitados:** muitos dispositivos IoT têm recursos limitados, tornando difícil implementar medidas de segurança mais sofisticadas.

3. **Atualizações de software:** grande parte dos dispositivos IoT não recebem atualizações de *software* regulares, tornando-os vulneráveis a ataques.



Malware

- Riscos do Malware em IoT:

1. **Invasão de privacidade**: malware pode acessar e roubar informações pessoais e sensíveis.

2. **Controle remoto**: malware pode permitir que atacantes controlem dispositivos IoT remotamente.

3. Ataques DDoS: botnets de dispositivos IoT podem ser usados para realizar ataques de negação de serviço (DDoS).

4. **Danos físicos**: malware pode causar danos físicos a dispositivos IoT ou a sistemas críticos.

Malware

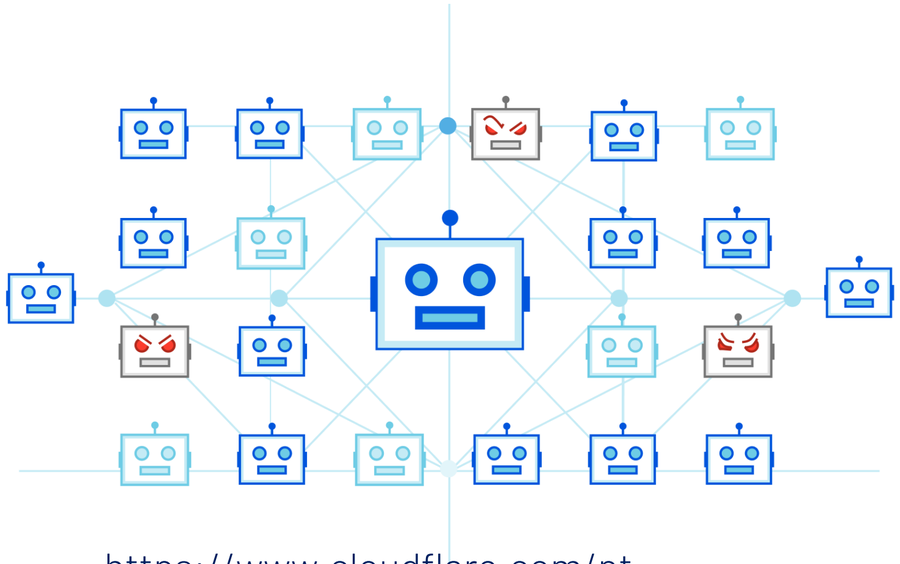
- Ex. de *malware* IoT - Mirai:

1. É um malware que se tornou conhecido por infectar dispositivos IoT (Internet das Coisas) e utilizá-los para lançar ataques DDoS em larga escala.

Como funciona:

O Mirai verifica a internet em busca de dispositivos de IoT que são executados no processador ARC. Este processador executa uma versão simplificada do sistema operacional Linux.

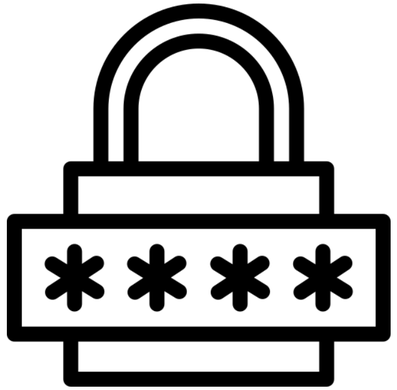
Esses dispositivos podem ser babás eletrônicas, veículos, roteadores de rede, dispositivos agrícolas, dispositivos médicos, dispositivos de monitoramento ambiental, eletrodomésticos, DVRs, câmeras CC, fones de ouvido ou detectores de fumaça.



https://www.cloudflare.com/pt-br/learning/ddos/glossary/mirai-botnet/

Malware

- Prevenção e mitigação de danos:

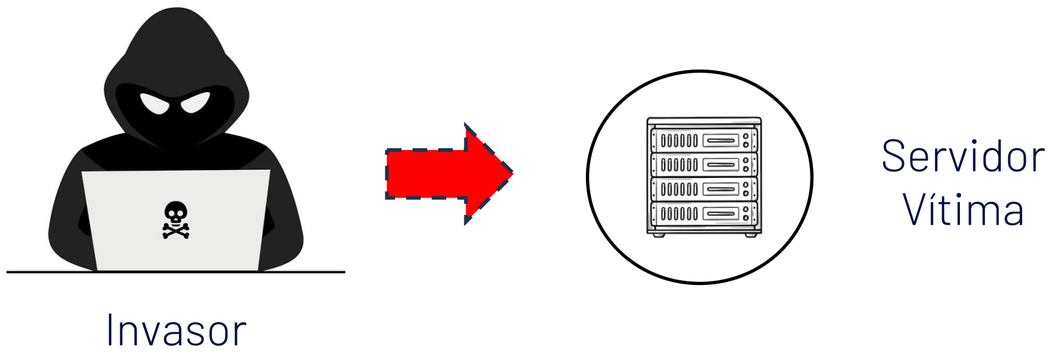


1. **Segurança por design**: projetar dispositivos IoT com segurança em mente desde o início.
2. **Atualizações de software**: realizar atualizações de software regulares para corrigir vulnerabilidades.
3. **Autenticação**: e autorização: implementar mecanismos de autenticação e autorização robustos.
4. **Monitoramento de rede**: monitorar a rede IoT para detectar atividades suspeitas.

Ataque DDoS

- DoS – *Ataque de Negação de Serviço*:

✓ Um ataque de DoS é um tipo de ataque cibernético que visa sobrecarregar um sistema ou rede com tráfego de dados excessivo, tornando-o indisponível para os usuários legítimos.



Consequências:

1. Indisponibilidade da rede;
2. Perda de produtividade;
3. Danos à reputação da empresa.

Ataque DDoS

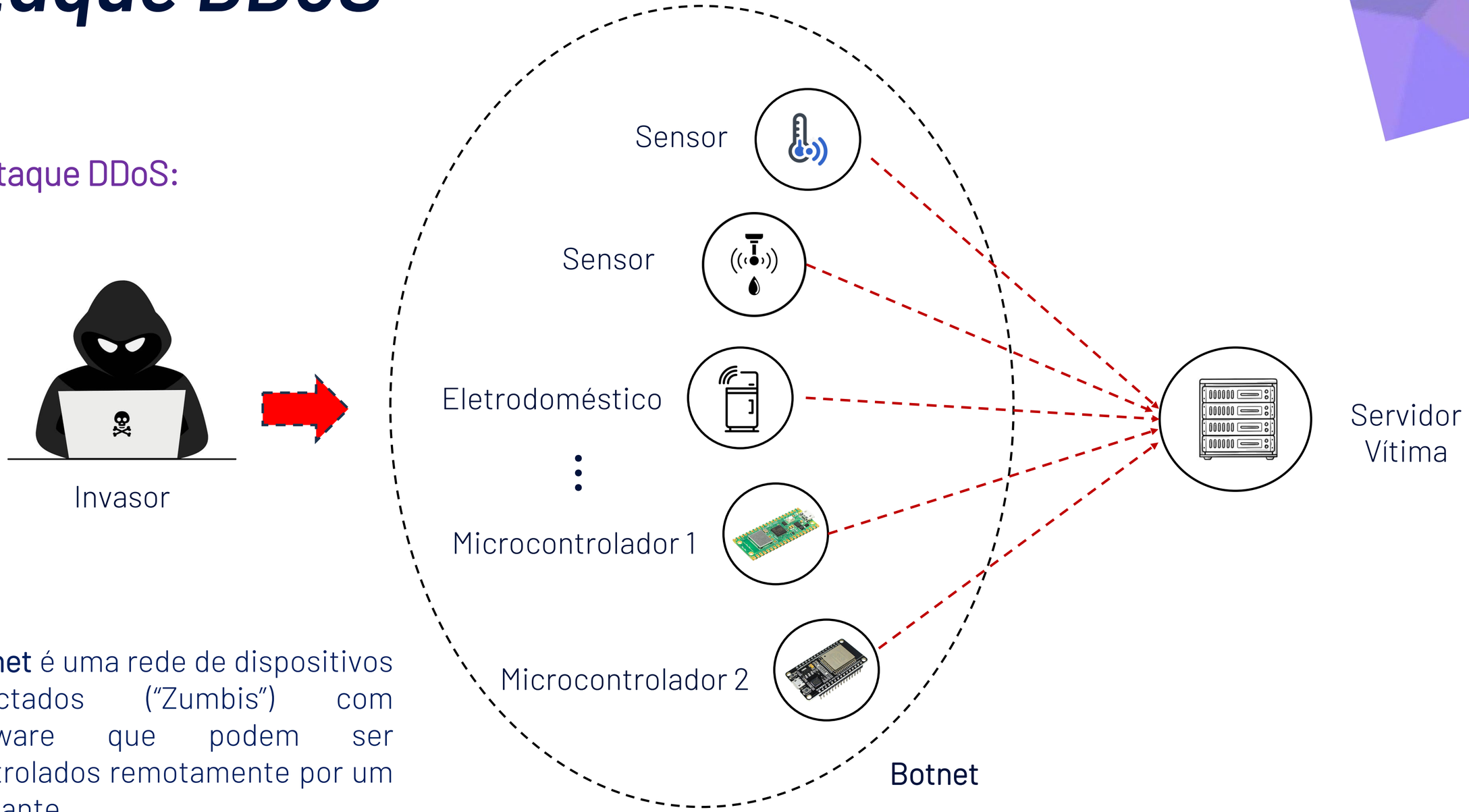
- ✓ **DoS**: O ataque é lançado a partir de um único local.
- ✓ **DDoS (Ataque Distribuído de Negação de Serviço):** O ataque é lançado a partir de múltiplos locais, tornando-o mais difícil de mitigar.

Tipos de ataques DDoS:

1. **HTTP Flood**: envia solicitações HTTP para sobrecarregar o sistema alvo.
2. **TCP SYN Flood**: envia solicitações de conexão TCP para sobrecarregar o sistema alvo.
3. **UDP Flood**: um ataque que envia pacotes UDP para sobrecarregar o sistema alvo.

Ataque DDoS

Ataque DDoS:



Botnet é uma rede de dispositivos infectados ("Zumbis") com malware que podem ser controlados remotamente por um atacante

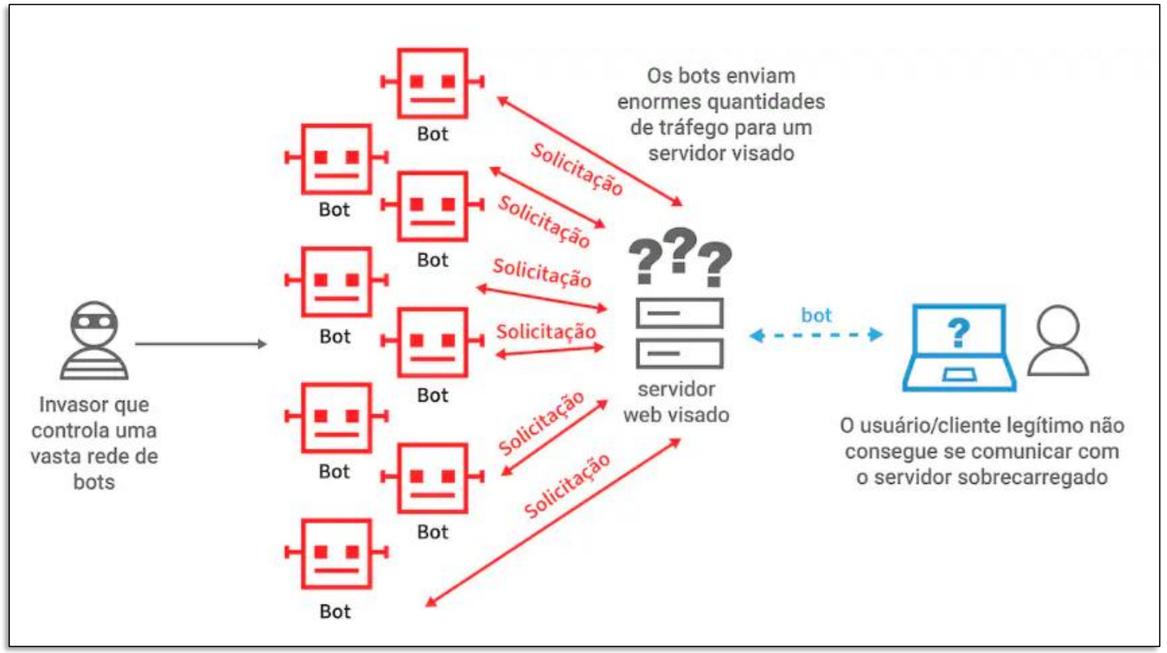
Ataque DDoS

- DDoS – *Exemplo de ataque*:

✓ Ataques Volumétricos: Sobrecarga a largura de banda da rede alvo, inundando-a com tráfego excessivo. Ex: Inundações de UDP, ICMP, ou SYN.

✓ Ataques de Aplicação: Visam a camada de aplicação (HTTP, etc.) para consumir os recursos do servidor. Ex: baseados em protocolos como HTTP Flood.

✓ Ataques de Exaustão de Recursos de Hardware: Sobrecarga a capacidade de processamento de equipamentos de rede (roteadores, firewalls, etc.).



https://www.akamai.com/pt/glossary/what-is-a-volumetric-attack

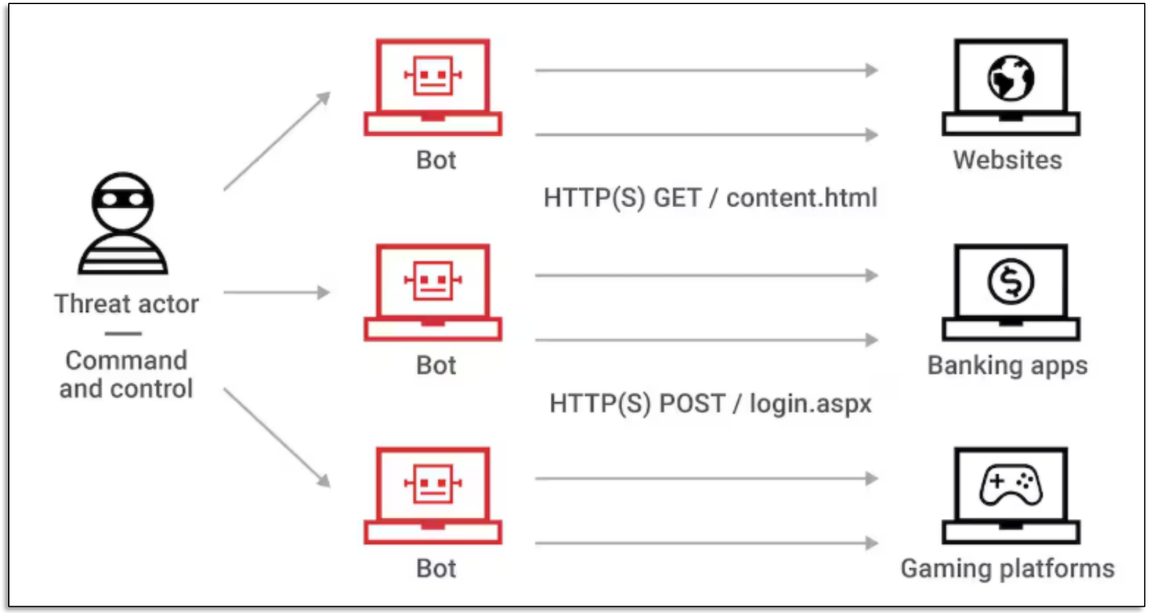
Ataque DDoS

- DDoS – *Exemplo de ataque*:

✓ Ataques de Aplicação: Visam a camada de aplicação (HTTP, etc.) para consumir os recursos do servidor.

Ataques *Slowloris*:

Um ataque de DDoS *Slowloris* usa solicitações HTTP parciais para abrir o máximo possível de conexões entre um único computador e um servidor Web visado, o que sobrecarrega o alvo e faz com que ele diminua a velocidade ou negue o serviço a solicitações legítimas.



https://www.akamai.com/pt/glossary/what-is-application-layer-ddos-attack

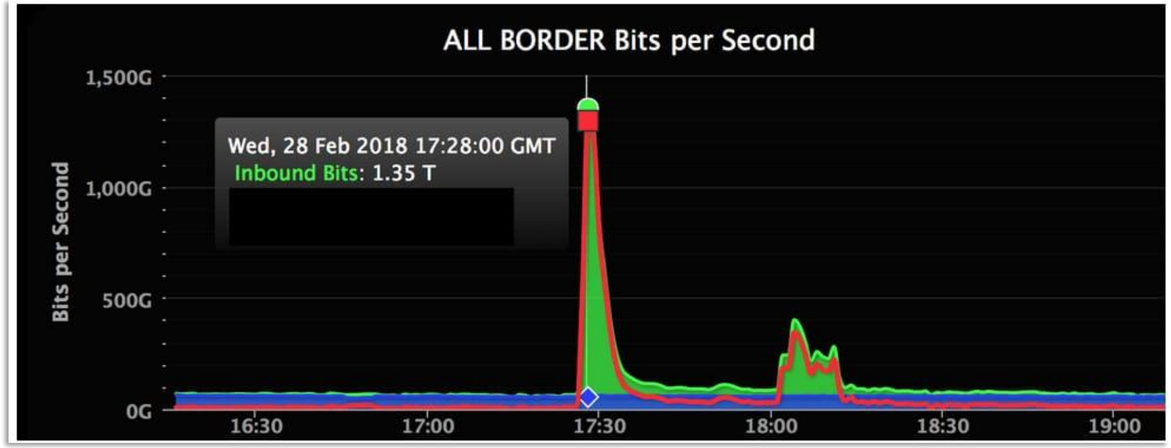
Ataque DDoS

- DDoS – *Exemplo de ataque*:

✓ Em 28 de fevereiro de 2018, o GitHub.com (maior plataforma de hospedagem de código-fonte no mundo) ficou indisponível das 17:21 às 17:26 UTC e, intermitentemente, indisponível das 17:26 às 17:30 UTC devido ao ataque distribuído de negação de serviço (DdoS);

✓ Pico de 1,35 terabits por segundo de tráfego - 126,9 milhões de pacotes por segundo;

✓ Houve um segundo pico de 400 Gbps.



https://github.blog/news-insights/company-news/ddos-incident-report/

Ataque DDoS

- DDoS – *Como se preparar para os ataques*:

✓ **Conhecer a organização**: fazer uma análise de risco;

✓ **Conhecer o padrão de uso**: identificar média e os picos de tráfego na rede;

✓ **Reduzir as possibilidades de ataque**: a) fazer um inventário da rede; b) desativar os serviços desnecessários etc;

✓ **Proteger os recurso que podem ser atacados**: manter os servidores e equipamentos atualizados;

✓ **Preparar para absorver e filtrar o ataque**: analisar a resiliência da rede e dos sistemas.

cert.br

Centro de Estudos, Reposta e Tratamento de Incidentes de Segurança do Brasil

https://www.cert.br/docs/whitepapers/ddos/

Ataque DDoS

- DDoS – *Detecção e Análise*:

✓ **Descartar outras opções de problemas:** problema de atualização, conectividade, campanha de marketing?

✓ **Tentar identificar o tipo de ataque**: se é volumétrico, de aplicação, de exaustão de recursos de hardware ou misto.

✓ **Levantar detalhes sobre o ataque**: horário de início e de fim, serviços que estão sendo usados etc.

✓ **Determinar o Impacto**: sistemas críticos que afetam a imagem?

✓ **Se antecipar a novos ataques**: alguns ataques ocorrem em "ondas" ou são uma distração para as equipes de segurança.

cert.br

Centro de Estudos, Reposta e Tratamento de Incidentes de Segurança do Brasil

https://www.cert.br/docs/whitepapers/ddos/

Ataque DDoS

- DDoS – *Mitigação dos danos*:

Documentar as ações tomadas: o registro das ações irá ajudar a relatar os problemas.

Distribuir o alvo do ataque: usar recursos para distribuir o tráfego do ataque entre diferentes servidores.

Tentar mitigar os ataques à camada de aplicação: over a aplicação para uma máquina com mais capacidade de processamento.

Notificar as redes que estão gerando o ataque: informar as redes que estão gerando o ataque para que tomem medidas para interromper essa atividade maliciosa.

cert.br

Centro de Estudos, Reposta e Tratamento de Incidentes de Segurança do Brasil

https://www.cert.br/docs/whitepapers/ddos/

Spoofing

- *Spoofing* (Mascaramento):

✓ É uma técnica de ataque cibernético que envolve a falsificação de identidade ou informações para enganar sistemas, dispositivos ou pessoas.

Spoofing

- *Spoofing* (Mascaramento) – principais riscos:

✓ **Acesso não autorizado**: permitir que atacantes obtenham acesso não autorizado a sistemas e redes IoT.

✓ Roubo de informações: roubar informações sensíveis, como dados de usuários ou chaves de criptografia.

✓ **Danos ao sistema**: causar danos ao sistema, como a interrupção de serviços ou a modificação de configurações.

✓ **Ataques de *phishing*:** enganar usuários para que revelem informações sensíveis.

Spoofing

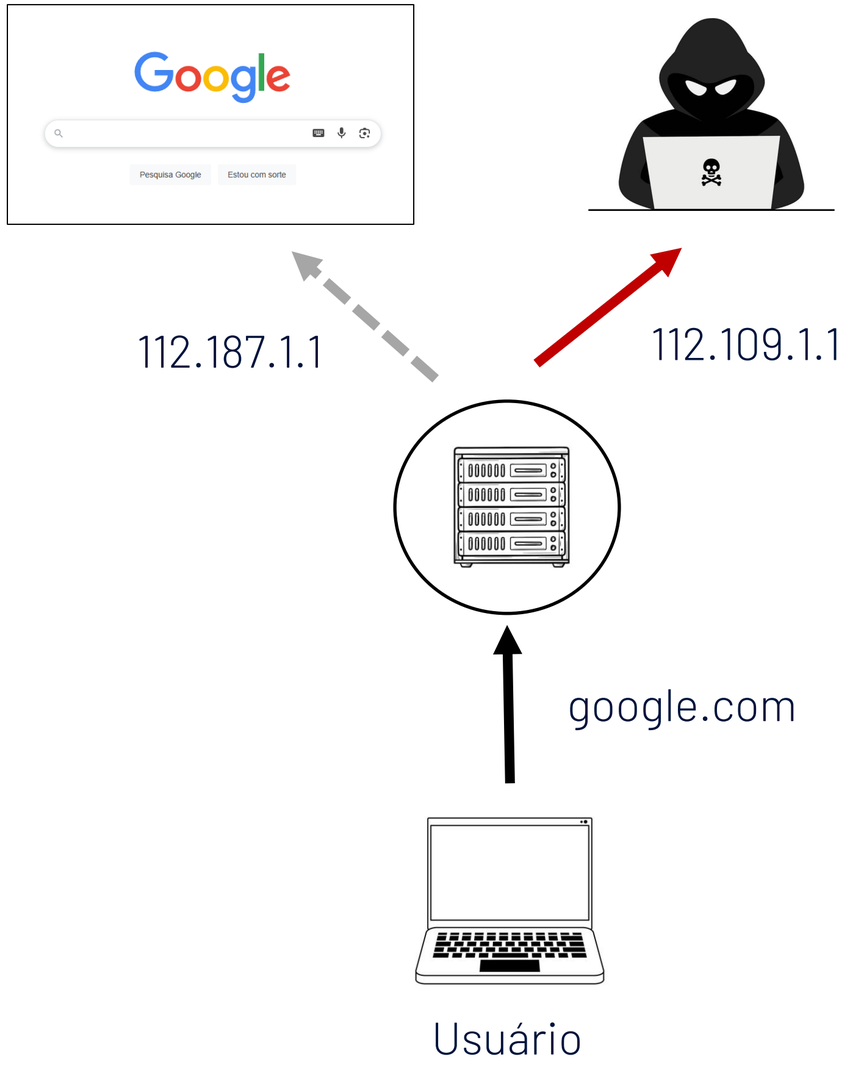
- *Tipos de Spoofing*:

1. **IP Spoofing**: falsificar o endereço IP de um dispositivo ou sistema.

2. **DNS Spoofing**: falsificar as respostas de um servidor DNS.

3. **E-mail Spoofing**: falsificar o endereço de e-mail de um remetente.

4. **Device Spoofing**: falsificar a identidade de um dispositivo largura de banda da rede alvo, inundando-a com tráfego excessivo.



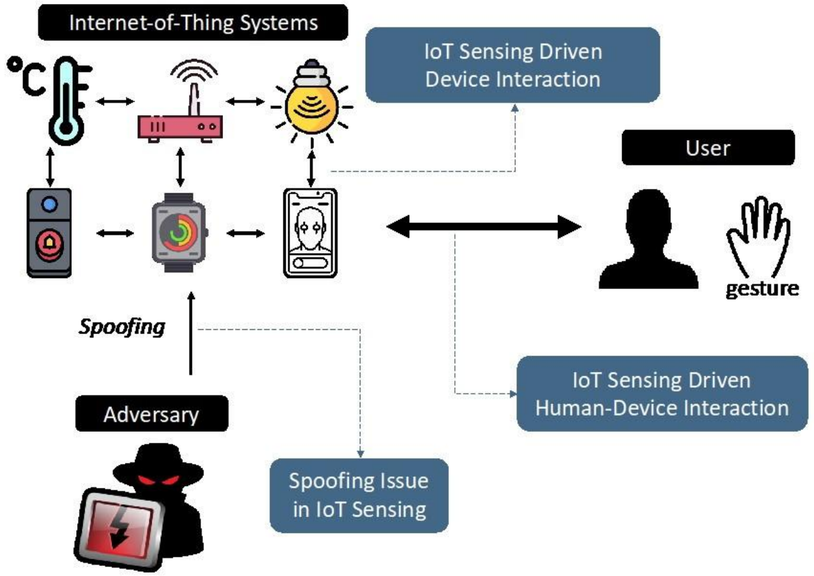
Spoofing

- *Spoofing – no contexto de IoT*:

1. *Spoofing* de dispositivo: falsificar a identidade de um dispositivo IoT para obter acesso a uma rede ou sistema.

2. *Spoofing* de IP: falsificar o endereço IP de um dispositivo ou sistema para ocultar a origem de um ataque.

3. *Spoofing* de MAC: falsificar o endereço MAC de um dispositivo para obter acesso a uma rede.

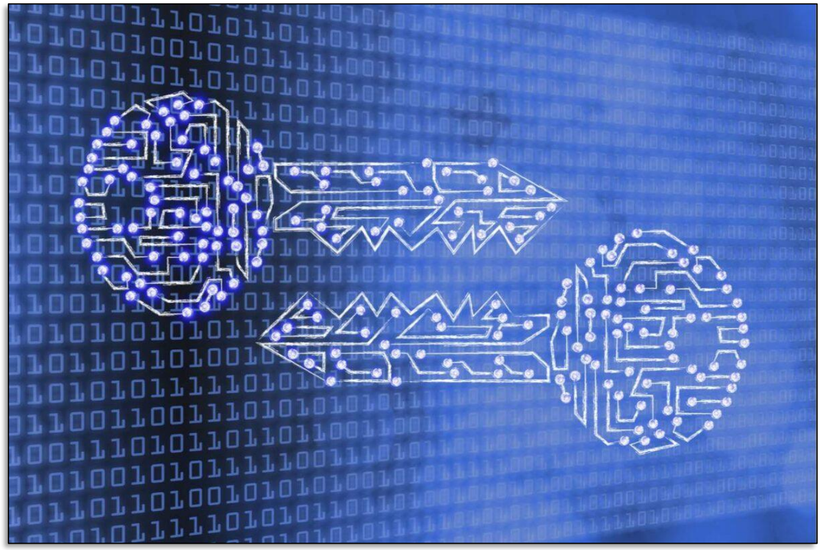


https://cse.hkust.edu.hk/pg/research/projects/qianzh/iot-sensing/

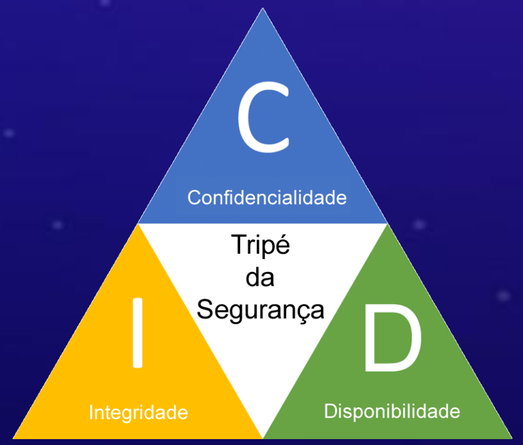
Spoofing

- *Spoofing – Prevenção e mitigação*:

1. **Autenticação**: implementar mecanismos de autenticação robustos.
2. **Criptografia**: utilizar criptografia para proteger as comunicações.
3. **Monitoramento**: monitorar as comunicações e os sistemas para detectar atividades suspeitas.
4. **Educação do usuário**: educar os usuários sobre a importância da segurança cibernética e como evitar ataques de spoofing.



Princípios básicos em segurança da informação



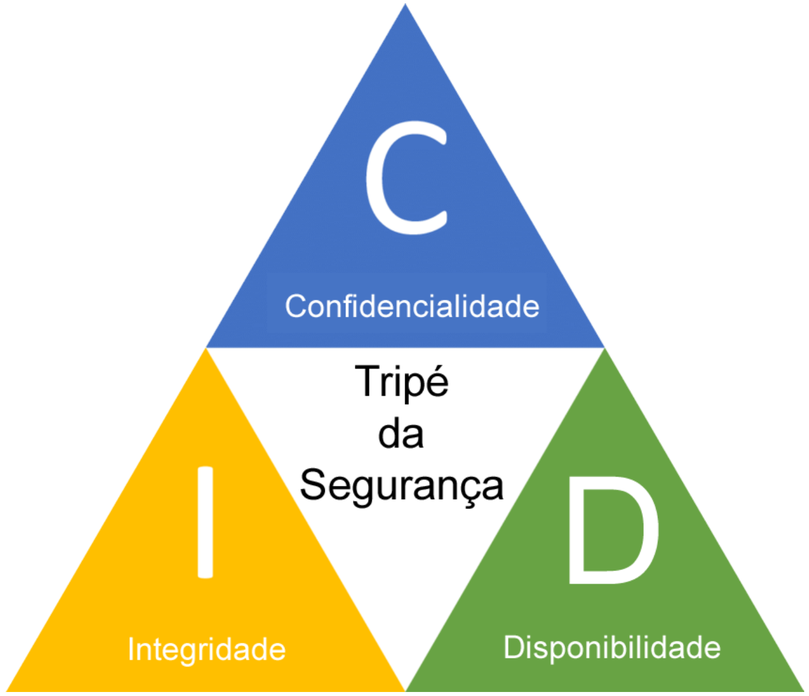
Principios de segurança

- Os três princípios fundamentais da segurança da informação:

1. **Confidencialidade**: Proteger os dados contra acessos não autorizados, garantindo que apenas usuários ou sistemas devidamente autorizados possam acessar informações sensíveis.

2. **Integridade**: Garantir que os dados não sejam alterados sem autorização.

3. **Disponibilidade**: assegura que os dados e dispositivos estejam acessíveis sempre que necessário.



Principios de segurança

- Os três princípios fundamentais da segurança da informação:

1. **Confidencialidade**: Proteger os dados contra acessos não autorizados, garantindo que apenas usuários ou sistemas devidamente autorizados possam acessar informações sensíveis.

Para alcançar a confidencialidade, técnicas como **criptografia** são amplamente utilizadas, proporcionando proteção contraespionagem e acessos indevidos.

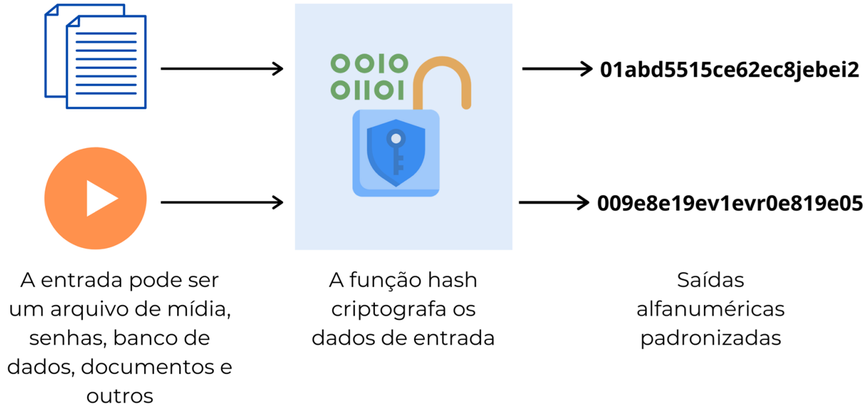
https://www.scunna.com/como-a-criptografia-protege-o-nosso-dia-a-dia/

Principios de segurança

- Os três princípios fundamentais da segurança da informação:

2. **Integridade**: Garantir que os dados não sejam alterados sem autorização.

Ferramentas como assinaturas digitais e funções de hash desempenham um papel crucial na detecção de alterações e na manutenção da confiabilidade dos dados em trânsito ou armazenados.



https://voitto.com.br/blog/artigo/o-que-e-hash-e-como-funciona

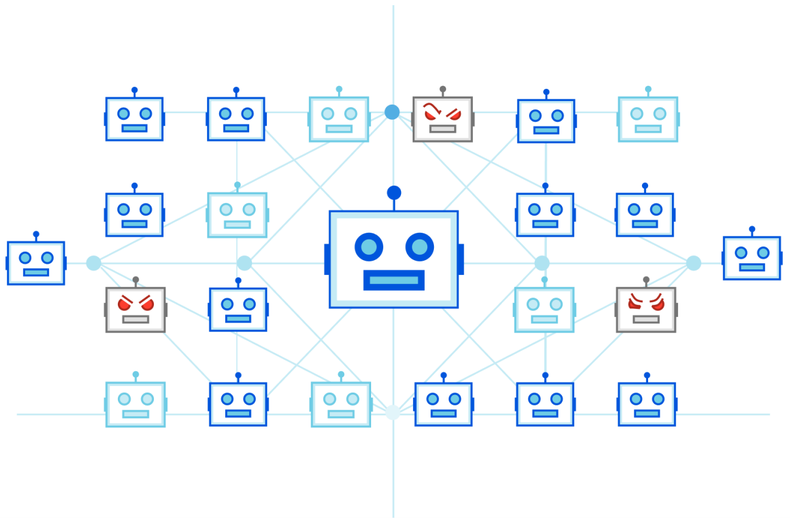
Função hash: é um algoritmo matemático para a criptografia, na qual ocorre uma transformação do dado (como um arquivo, senha ou informações) em um conjunto alfanumérico com comprimento fixo de caracteres - é utilizada para resumir dados, verificar integridade de arquivos e garantir a segurança de senhas, dos arquivos e das informações armazenadas dentro de um servidor.

Principios de segurança

- Os três princípios fundamentais da segurança da informação:

3. **Disponibilidade**: assegura que os dados e dispositivos estejam acessíveis sempre que necessário.

A proteção contra ataques DDoS, que podem tornar serviços indisponíveis, é uma estratégia importante para garantir a continuidade operacional.



Principios de segurança

- No contexto de IoT, pode-se destacar dois princípios adicionais:

4. **Autenticação:** garante que a fonte dos dados seja devidamente identificada, evitando interações com dispositivos ou usuários não autorizados.

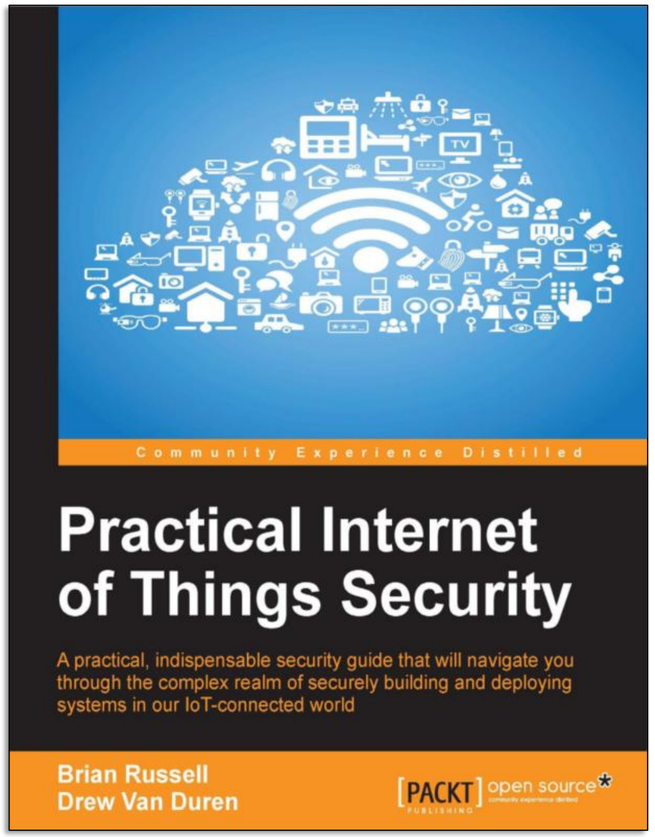
5. **Não repúdio**: assegura que indivíduos ou sistemas não possam negar ações realizadas anteriormente. Por exemplo, em uma rede IoT industrial, a rastreabilidade das ações é fundamental para garantir responsabilidade e confiabilidade.

Conclusões

Conclusões

- Exploramos os principais riscos que envolvem segurança da informação, a exemplo de malwares, ataques DDoS e spoofing;
- Avaliamos técnicas de detecção e análise de riscos associados à segurança de sistemas IoT;
- Abordamos os conceitos fundamentais de segurança da informação, incluindo confidencialidade, integridade e disponibilidade.
- Deixamos o caminho “pavimentado” para explorar os conceitos de criptografia em futuras aulas.

Bibliografia Recomendada



sensors MDPI

Review

Internet of Things: Security and Solutions Survey

Pintu Kumar Sadhu [1,*], Venkata P. Yanambaka [2] and Ahmed Abdelgawad [1]

1 College of Science and Engineering, Central Michigan University, Mount Pleasant, MI 48858, USA
2 Department of Mathematics and Computer Science, Texas Woman's University, Denton, TX 76204, USA
* Correspondence: sadhu1pk@cmich.edu

Abstract: The overwhelming acceptance and growing need for Internet of Things (IoT) products in each aspect of everyday living is creating a promising prospect for the involvement of humans, data, and procedures. The vast areas create opportunities from home to industry to make an automated lifecycle. Human life is involved in enormous applications such as intelligent transportation, intelligent healthcare, smart grid, smart city, etc. A thriving surface is created that can affect society, the economy, the environment, politics, and health through diverse security threats. Generally, IoT devices are susceptible to security breaches, and the development of industrial systems could pose devastating security vulnerabilities. To build a reliable security shield, the challenges encountered must be embraced. Therefore, this survey paper is primarily aimed to assist researchers by classifying attacks/vulnerabilities based on objects. The method of attacks and relevant countermeasures are provided for each kind of attack in this work. Case studies of the most important applications of the IoT are highlighted concerning security solutions. The survey of security solutions is not limited to traditional secret key-based cryptographic solutions, moreover physical unclonable functions (PUF)-based solutions and blockchain are illustrated. The pros and cons of each security solution are also discussed here. Furthermore, challenges and recommendations are presented in this work.

Keywords: Internet of Things; security and privacy; cryptography; physical unclonable function; blockchain; authentication framework

check for updates

Citation: Sadhu, P.K.; Yanambaka, V.P.; Abdelgawad, A. Internet of Things: Security and Solutions Survey. *Sensors* **2022**, *22*, 7433. https://doi.org/10.3390/s22197433

Academic Editors: Hany Atlam and Nawfal Fadhel

Received: 8 September 2022
Accepted: 27 September 2022
Published: 30 September 2022

Publisher's Note: MDPI stays neutral with regard to jurisdictional claims in published maps and institutional affiliations.

Copyright: © 2022 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the Creative Commons Attribution (CC BY) license (https://creativecommons.org/licenses/by/4.0/).

1. Introduction

Devices like the Internet of Things (IoT) have a significant presence in our daily lives owing to the technological revolution, wireless devices, and communication systems. IoT has become a vital part of the digital era of Industry 4.0. The ability to bring physical things into the digital world is becoming more likely because of technology [1]. IoT networks have an impact on a variety of areas, including home monitoring and daily life patient monitoring. IoT integrates the advantage of data processing, analytics, and draws out the power of the web to make decisions for physical objects of the real world. It is a system where intelligent objects are linked and access the internet as the foundation of the interconnection to gather and share information using "Things". IoT has become one of the main focuses of research across the world.

1.1. Paper Organization

To depict the overall scenario and solutions, this paper is organized as Figure 1. To give an overview of the IoT ecosystem, security threats, and respective solutions to the new and existing researchers, this paper does a comprehensive review. To provide a better view, this paper shows the various applications of IoT, different security threats, security mechanisms, authentication frameworks, and future directions sequentially. Section 1 presents the overview of IoT, IoE, and data security and privacy. Section 2 shows the related work. The overview of different IoT applications, their importance, prospects, functionality, impact, and challenges are discussed in Section 3. After that, security constraints of IoT devices, attacks on the TCP/IP reference model's various layers, and attacks on each layer

Sensors **2022**, *22*, 7433. https://doi.org/10.3390/s22197433 https://www.mdpi.com/journal/sensors

embarca tech | Residência Tecnológica em Sistemas Embarcados

Segurança em IoT – Parte 1

RESIDÊNCIA – Aula Síncrona (17/06/2025)

Prof. Dr Ricardo Menezes Prates

Executores:
INSTITUTO FEDERAL Piauí
INSTITUTO FEDERAL Rio Grande do Norte
INSTITUTO FEDERAL Maranhão
INSTITUTO FEDERAL Ceará
cepedi
INSTITUTO HARDWARE BR
Coordenação: Softex
Iniciativa: MINISTÉRIO DA CIÊNCIA, TECNOLOGIA E INOVAÇÃO
GOVERNO FEDERAL BRASIL UNIÃO E RECONSTRUÇÃO